

Cyber Assessment

Versão 4.2

Relatório técnico de andamento • 28 de setembro de 2026

Segurança, integridade das integrações e rastreabilidade das correções do ERP Flow. Esta emissão consolida a avaliação V4.1, duas rodadas de tratamento e a revisão adicional N01–N04, com evidências vinculadas ao código.

4

novos achados tratados no código

N01–N04; reteste de ambiente
pendente

20

itens de backlog acompanhados

escopo integral ainda em execução

0

encerramentos operacionais
declarados

nesta consolidação

Parecer de acompanhamento

Há avanço técnico comprovável em autorização, sessões SAP, MFA, isolamento de contexto, limpeza local e prevenção de duplicidade de Drafts. Os vetores tratados possuem testes positivos e negativos. **Isso não comprova a implantação nem encerra as brechas no ambiente publicado.**

Permanecem pendências de rotação de segredos, restauração, TLS, revisão global de privilégios, dependências e homologação de fluxos completos. Não se atribui risco residual “nulo” ou certificação de segurança ao sistema.

Estado da emissão: documento V4.2 de acompanhamento. Correções implementadas no repositório; implantação e aprovação operacional não comprovadas. Nenhum acesso ao Supabase remoto ou SAP foi realizado nos ensaios registrados.

Commit de referência

f f8676ddb80e1f48d6e5bd16fbf8305180fa356a

Preparação: revisão técnica assistida e evidências do repositório.

Responsável pelo aceite / revisor independente: não registrados.

Distribuição recomendada: interna, para Engenharia, Segurança, QA e donos do processo.

Escopo e método

O que foi examinado — e o que a evidência permite concluir

Base	Uso e limite
V4.1 e memorando de verificação	Referência de F01–F15 e pendências originais. Relatos de reteste ao vivo não foram repetidos em produção.
V4.0, anexos, DOCX e avaliações anteriores	Histórico e confronto de alegações; não prevalecem sobre evidência de código e execução correspondente.
Código, migrações e callers	Revisão direcionada de handlers, helpers compartilhados, frontend e trilha Drizzle. Não é inventário exaustivo de toda a aplicação.
Ensaio locais	Handlers reais com fronteiras Auth/DB/ERP simuladas; PostgreSQL local com fixtures; Chrome com IndexedDB real. Sem dados de negócio reais.
Manifestos e saídas de testes	Permite conferir arquivos e resultados registrados. Hash comprova correspondência de bytes, não implantação, autoria de produção ou eficácia operacional.

Vocabulário de estados

Estado	Significado
Implementado / validado localmente	Código alterado e cenários descritos exercitados; não equivale a fechamento operacional.
Parcial / em andamento	Parte dos controles existe; cobertura, integração ou critério de aceite ainda incompleto.
Validação pendente	Não há evidência suficiente para concluir; não representa automaticamente exploração comprovada.
Dependência externa	Ação/evidência depende de infraestrutura, fornecedor ou dono de processo; não é aceite de risco.
Não sustentado	Alegação histórica sem correspondência suficiente no material examinado; não conta como correção entregue.

Limites da avaliação

- Gateway publicado, settings, grants produtivos, identidades reais, SAP/add-ons e scheduler implantado não foram inspecionados ao vivo.
- Ausência de autorização no handler não prova acesso anônimo ao gateway; RLS de usuário não limita automaticamente um client com service role.
- Os testes são registros de execução anteriores a esta emissão. A geração do PDF reconferiu os hashes da rodada 4.2, sem reexecutar suites ou aplicar migrações.
- P0/P1/P2 são prioridades propostas, não SLAs aprovados ou pontuações CVSS. Não há aceite formal de risco anexado.

Fontes de consolidação: [backlog V4.1](#); [registro V4.2](#); [revisão adicional](#).

F01–F08: evolução

Severidades históricas mantidas para rastreabilidade; estado atual é o desta coluna

ID / tema	Estado e avanço na V4.2	O que falta
F01 • Crítico Cadastro/domínio	Validação pendente. Guard de domínio existe; números de contas/settings são alegações históricas.	Export datado, cobertura das rotas e versão implantada. B20.
F02 • Crítico Identidade SAP	Implementação local do vetor de cache: HMAC e expiração em cada chamada; revogação/desligamento falham fechado.	Reteste publicado, latência e carga sem caches permissivos. B03.
F03 • Crítico ApiUser no browser	Vetor original do proxy tratado no código: vínculo ao caller e handle de serviço.	Cobertura de demais consumidores e privilégio SAP da conta técnica. B01/B20.
F04 • Crítico Exceção PagCorp	Vetor textual já tratado; autorização da origem passou a exigir ação create e empresa no guard.	Integração completa e perfis legítimos; outros consumidores. B01.
F05 • Crítico CNAB/favorecido	Dispatcher agora exige ação correspondente na empresa do corpo; testes das 12 ações.	Hash, autoaprovação, retorno e replay financeiro completo. B19.
F06 • Crítico Segredos	Cifra existente; não há prova de rotação/revogação ou recuperação da chave.	Rotacionar segredos expostos e testar custódia/recuperação. B05/B06.
F07 • Alto Backup/restore	Aberto quanto à recuperação. Jobs de backup não comprovam restauração integral.	Restore incluindo auth, chaves, vínculos e dados; tempo/resultado documentados. B06.
F08 • Alto TLS/perímetro	Dependência externa e trabalho no app; defaults HTTP e configuração efetiva permanecem pendentes.	TLS válido, allowlist, certificados/downgrade e evidência do fornecedor. B07.

F02 foi reaberto na revisão local apesar do fechamento declarado no V4.1. A correção implementada agora trata o vetor reproduzido; não deve ser extrapolada para todas as sessões ou rotas.

Evidências de suporte: rodada 1; testes de guards e handlers; migração 0063.

F09–F15 e alegações contestadas

Continuidade do diagnóstico, sem promover correção parcial a encerramento

ID / tema	Avanço / estado atual	Pendência principal
F09 • Alto MFA administrativo	Fallback SAP preserva recusa Cloud; erro de papel bloqueia. Reset próprio proibido, contador estrito e auditoria prévia.	Validade temporal, integração Auth, matriz de rotas e cenários IdP. B04/B16.
F10 • Alto Copiloto/SQL	Ator/client de confirmação por chamada, sem globais compartilhados.	Grants SELECT/EXECUTE, leitura indireta e demais confirmações. B08/B12.
F11 • Alto Autoria/isolamento	Empresa/ação no guard; exceção Omie removida; autoria de colaboradores agora deriva de identidade.	Cobertura global de módulos/polices e homologação de grupos. B01/B12/N04.
F12 • Médio Impersonação	Consulta sem cache permissivo; erro bloqueia; fallback mantém recusa.	Todas as escritas REST/RPC/Edge/SAP e tabelas novas. B09.
F13 • Médio Logout/local	Exclusão aguardada; blocked/error observáveis; dono conferido na fila. Cinco cenários Chrome passaram.	Empresa nos snapshots, gravações tardias e requests em andamento. B10.
F14 • Médio IA/documentos	Parcial. Controles originais não cobrem todos os formatos ou conteúdo nos pixels.	Minimização, retenção, provedor e aprovações organizacionais. B11.
F15 • Médio Inventário/cron	Dois schedulers protegidos na rodada 4.2; inventário global não concluído.	Contas técnicas/demo, segredos cron, versões, dependências e recertificação. B13–B15.

F16–F20 dos anexos V4.0

As referências históricas a `omie-webhook`, `bucket expense-docs`, `responseHandler.ts`, `mfa-reset/reports-generator` e `policy PrestadorAccess` não corresponderam ao checkout examinado. Permanecem **não sustentadas como descritas**; não contam como cinco correções adicionais.

As classes de risco continuam cobertas pelo backlog: inventário, storage, sanitização de erros, reset real de MFA e revisão de RLS/grants. Ausência no repositório não comprova ausência de objetos criados manualmente em produção.

Detalhamento: [matriz histórica](#), [interpretações e estados de execução](#).

Controles implementados nas primeiras rodadas

Evidência por controle e limite de cobertura

Controle / pontos de código	Evidência registrada	Ponderação
Empresa e ação auth.ts, company-access.ts, credenciais, CNAB, PagCorp; SQL 0063	15 testes de segurança incluem body × header, escrita negada, admin global e dispatcher CNAB; 14 verificações SQL.	Remover autorização implícita Omie pode bloquear usuários sem vínculo/grupo explícito. Revisar concessões antes de liberar.
Documento fiscal nf-entrada-fetch-file	Anônimo barrado antes do DB; outra empresa barrada antes de assinatura; leitura permitida preservada.	Storage, gateway, provedor e download real ainda não exercitados.
Sessões e MFA auth.ts, session-revocation.ts	Provas ausentes/expiradas/adulteradas; troca de empresa; revogação; erros RPC; AAL1 recusado com fallback SAP; AAL2 permitido.	Mais consultas por requisição. Medir disponibilidade e latência; falhar fechado muda comportamento em indisponibilidade.
Confirmação de IA copilot-chat	Chamadas intercaladas mantêm donos distintos; argumento confirmado vindo do cliente não autoriza sozinho.	Não comprova limites de todas as ferramentas, SQL ou ausência de prompt injection.
Reset MFA mfa-admin-reset	Reset próprio negado; falha de auditoria inicial impede remoção; reset por outro admin e auditoria final exercitados.	Falha de auditoria final pode ocorrer após remover fatores; API informa resultado parcial. Auth real pendente.
Erros de handlers	Mensagem inesperada genérica em credenciais e documento fiscal.	Revisão ampla de mensagens/logs continua B17.

Rastreabilidade

EV01 — saída dos 15 testes

EV02 — 14 verificações PostgreSQL

EV03 — manifesto e resultados da rodada 1

Os totais de testes não são contagem de vulnerabilidades. Há cenários sobrepostos e fronteiras simuladas. Não somar suites diferentes para anunciar cobertura percentual do sistema.

N01 e N02: autorização e estado fiscal

Prioridade P0 proposta • implementados; reteste de ambiente pendente

N01 — rotas privilegiadas sem autorização de negócio

Antes: `nf-entrada-to-sap`, `audit-cross-fiscal-run` e `employees-sync-run` chegavam a operações com service role sem validar usuário, empresa ou ação no handler. Os ensaios capturaram criação de Draft, exclusão de resultados fiscais e registro de execução com solicitações sem identidade.

Agora: `integration-auth` autentica antes da consulta e exige `integrate` na empresa obtida do recurso, nos módulos `nf_entrada`, `fiscal_audit` e `employee_integration`. Execução de NF em lote exige identidade técnica. Os callers `employees-sync-cron` e `audit-cross-fiscal-auto` também exigem identidade técnica, para não servir de contorno com credencial de serviço.

Evidência: cinco entradas negam anônimo antes do banco; empresa divergente não chega a `adapter/lock/escrita`; fluxo permitido e schedulers autenticados continuam operando nas fixtures. A sincronização de colaboradores mantém a restrição a bases TST.

Não foi provado acesso anônimo ao gateway publicado. Service role continua sendo uma credencial ampla: rotação e identidade técnica com menor privilégio permanecem no backlog.

N02 — nota cancelada/rejeitada reprocessada por ID

Antes: a seleção por ID ignorava o filtro de elegibilidade da seleção em lote; notas `cancelled` e `erpflow_rejected` sem Draft geravam documento e voltavam a `awaiting_sap`.

Agora: o fluxo comum recusa cancelada, rejeitada no Flow/SAP e concluída. Sem Draft existente, aceita apenas `pending_expense/integration_error`. A reserva SQL confere o estado corrente; cancelamento/rejeição/conclusão aguardam reconciliação durante resultado incerto. A atualização do vínculo exige o status esperado, evitando sobrescrever mudança concorrente.

Aceite de ambiente: negar sem efeito as transições proibidas; preservar integração elegível; testar mudança concorrente de status e reabertura explicitamente aprovada. Draft não equivale a pedido definitivo nem pagamento.

Referências: [guard compartilhado](#); [handler fiscal](#); [EV06 — testes V4.2](#).

N03 e N04: duplicidade e autoria

Prioridade P1 proposta • implementados; operação assistida ainda necessária

N03 — criação concorrente ou resultado incerto de Draft

Antes: dois handlers liam `sap_po_draft_id=null` e criavam dois Drafts antes de persistir o vínculo. A checagem no snapshot não era uma reserva atômica.

Agora: tabela `nf_po_draft_jobs` com chave exclusiva por NF e estados `processing` → `completed` ou `uncertain`. RLS e grants restringem o acesso de aplicação à service role. A correlação `ERPFlow NF <id>` permite localizar o documento antes de repetir. Resultado incerto autoriza reconciliação, **não outro POST**. A confirmação durável precede o vínculo na NF.

Prova local	Resultado
Duas reservas simultâneas no PostgreSQL	Apenas uma prossegue; a outra encontra a chave exclusiva.
Duas reconciliações do mesmo resultado incerto	Apenas uma adquire a transição condicional.
Timeout após gravação / falha na confirmação local	Draft localizado e reutilizado; sem segundo POST nos ensaios.
Nenhum Draft encontrado após resultado incerto	Operação permanece bloqueada para reconciliação; não assume falha remota.
Cancelamento durante processamento	Trigger SQL recusa a mudança até resultado conhecido.

Ponderação: reservas não expiram automaticamente. Worker interrompido pode exigir recuperação assistida. Drafts legados não contêm a nova correlação: reconciliar antes da liberação. Não há transação distribuída ou garantia absoluta contra duplicidade externa ao fluxo.

N04 — autoria escolhida no corpo da requisição

Antes: `triggered_by` e `triggered_by_email` vinham do corpo. **Agora:** derivam da identidade verificada; usuários não escolhem autoria nem tipo `scheduled`. Jobs registram `service:integration-scheduler` com `user_id` nulo. O teste preserva execução humana/técnica e ignora os valores forjados.

Evidência: [migração 0064](#); [reserva/reconciliação](#); [EV08 — PostgreSQL](#); [EV06 — cenários de autoria e retry](#).

Logout e isolamento do estado local

F13 / B10 • implementação parcial com validação em navegador

A rodada 2 tratou duas causas: a exclusão de IndexedDB era iniciada sem aguardar o resultado, e uma lista capturada pela outbox podia chegar ao sender depois da troca de conta.

Controle	Comportamento atual
Exclusão aguardada	Os dois bancos locais são excluídos por Promise. Erro ou bloqueio além de cinco segundos rejeita a limpeza. Timeout não cancela a exclusão pendente do navegador.
Conexões abertas	Persistência de anexos fecha em versionchange. Outbox aguarda oncomplete da transação e trata erro/abort.
Dono do item	Alteração/exclusão conferem o dono na mesma transação; flush confere identidade por item e depois da espera assíncrona.
Troca durante o envio da fila	Se a conta mudou antes do sender, o item não é enviado e volta a pending para o dono original retomar.
UX de logout	Callers aguardam limpeza antes do redirecionamento; falha é informada. SIGNED_OUT global registra falha, mas não desfaz uma saída já ocorrida.

Cinco cenários Chrome registrados

- B não lista, altera ou exclui o item de A; o payload de A é preservado.
- Troca durante flush não envia; A retorna e consegue concluir o envio.
- Duas abas: a exclusão aguarda a outra conexão fechar e os bancos desaparecem.
- Conexão mantida aberta: timeout rejeita a limpeza; fechar a aba permite concluí-la.
- Limpeza remove estado escopado, preserva tema e permite a B usar a fila após reload.

Riscos que permanecem

Snapshots ainda não são particionados por empresa. Faltam barreira para gravações tardias/reabertura durante limpeza, testes de troca rápida entre abas e associação/cancelamento de requests já iniciados. Concorrência de envio e idempotência financeira continuam em B19; este ensaio não comprova ausência de duplicidade.

EV04: [saída Chrome com IndexedDB real](#). [Método e limites](#). Identidade e circuito ERP foram simulados; não houve login real no Auth.

FUNC-01: PATCH completo da despesa

Ajuste funcional separado dos achados de segurança

Incidente informado: despesa aprovada e integrada ao SAP, depois editada e reaprovada, chegava com valores zerados. Não foi capturada a ocorrência real no SAP; não se atribui causa exclusiva sem essa evidência.

**Edição validada → persistência dos itens → nova aprovação
→ expense-to-sap / patch_document → PATCH + releitura SAP**

A implementação anterior já tentava atualizar o documento completo, mas ignorava falha de leitura das linhas, reconstruía IDs sequencialmente e não tratava a ausência de linha como erro na conferência de preço. Campos omitidos também podiam conservar estado anterior.

Mudança	Finalidade / limite
Snapshot obrigatório antes do PATCH	Falha de leitura ou coleção inválida impede payload incompleto.
Cabeçalho e coleção completa	Campos graváveis selecionados e UDFs são preservados; dados aprovados prevalecem. Substituição da coleção por B1S-ReplaceCollectionsOnPatch.
IDs de linha e campos explícitos	Preserva IDs com lacunas; SAP atribui IDs novos. Envia gratuito tYES/tNO e permite limpar CC/projeto quando a regra resolve valor vazio.
Valores e conferência	UnitPrice/Price aprovados; se recalculados para zero, segundo PATCH de preço e releitura. Linha ausente ou divergência persistente impede sucesso.
Campos protegidos	Não reenvia totais calculados, IDs do documento, filial, moeda ou datas contábeis originais; DocDueDate é atualizado.

Evidência e ressalvas

O teste integrado usa a montagem real do payload e o fluxo de envio. O SAP simulado zera o primeiro PATCH; a segunda correção confirma $2 \times 506,50 = 1.013,00$, conservando cabeçalho, anexo, UDFs, CC, projeto e ID de linha. Seis testes adicionais cobrem o helper, falha de leitura, adição/remoção e conferência de preços.

A associação de linhas existentes continua posicional. Campos não representados pelo formulário, remoção total de anexos e especificidades de add-ons não foram ampliados. Homologar o ciclo real completo, impostos, UDFs, linhas gratuitas e documentos encerrados.

EV06/EV07: testes do PATCH; montagem completa; conferência de preços.

Painel de evidências e qualidade

Resultados registrados — não reexecução dos testes na emissão deste PDF

ID / verificação	Resultado	Alcance e limite
EV01 • Segurança rodada 1	15 testes passaram	Node/VM, código real com fronteiras simuladas.
EV02 • SQL rodada 1	14 verificações passaram	PostgreSQL local, funções de 0063 em schema sintético; não replay integral.
EV04 • Estado local	5 cenários Chrome passaram	IndexedDB real, duas abas/reload; identidade e ERP simulados.
EV05 • Reprodução N01–N04	Comportamentos vulneráveis reproduzidos no baseline	Artefato histórico; script de reprodução não é teste de aceite do código corrigido.
EV06 • Fluxos V4.2	12 testes passaram	Autorização, estado, concorrência simulada, autoria, retry e reaprovação.
EV07 • Helpers PATCH	6 testes passaram	Vitest; leitura, campos, linhas, IDs e valores. Também integram a suíte geral.
EV08 • SQL 0064	6 cenários passaram	Concorrência real de duas conexões, elegibilidade/transição, grants e RLS.
Build frontend	Passou	Aviso de chunks grandes; não equivale a checagem das Edge Functions.
Vitest geral	247 passaram / 49 ignorados / 1 falhou	Falha pré-existente em report-pdf.test.ts:179, expectativa #abcdef12.
EV09 • Deno (4 rotas centrais)	25 erros antes e 25 depois	Sem novo diagnóstico por mensagem/arquivo; checagem continua reprovaada.

Não somar testes Node, Vitest, SQL e browser como uma única cobertura. Os escopos se sobrepõem; testes ignorados não são testes aprovados. Quantidade de erros igual antes/depois não prova correção de tipos.

A comparação Deno desta rodada considera NF, colaboradores, auditoria fiscal e expense-to-sap. A rodada anterior tinha outro conjunto de seis endpoints e 54 erros após ajustes; os números não são contraditórios nem comparáveis como tendência global.

Build e suíte geral estão registrados no documento da candidata; as saídas específicas e manifestos estão no repositório. Falta evidência correspondente ao ambiente efetivamente implantado.

Índice completo de caminhos e integridade: páginas 14–15.

Backlog consolidado • B01–B10

Estados operacionais: nenhum item declarado integralmente encerrado

Item	Estado	Avanço	Próxima evidência / área sugerida
B01 • P0	Parcial	Empresa/ação em rotas críticas e N01; guard Omie/SAP.	Inventariar demais consumidores e homologar perfis. Backend/IAM.
B02 • P0	Em reteste	Documento fiscal autenticado e autorizado antes de URL/download.	Gateway/storage/provedor e integração real. Backend/QA.
B03 • P1	Em reteste	HMAC/expiração em toda chamada; revogação fail-closed.	Reteste implantado e carga. IAM/QA.
B04 • P1	Parcial	Recusa MFA preservada no fallback; lookup de papel bloqueia em erro.	Sessões antigas, TTL, IdP e cobertura de rotas. IAM.
B05 • P1	Externa	Cifra existente; rotação não comprovada.	Rotacionar/revogar, inventariar custódia. Segurança/infra.
B06 • P1	A fazer	Recuperação integral não demonstrada.	Ensaio de restore com auth/keyring e evidência. Infra/banco.
B07 • P1	A fazer / externa	TLS/defaults e perímetro ainda pendentes.	Remover fallback inseguro e obter prova do fornecedor. Infra/backend.
B08 • P1	Parcial	Contexto do copiloto por chamada.	Grants SQL e todas as confirmações. IA/banco.
B09 • P1	Parcial	Falha de lookup/fallback não libera impersonação.	Matriz REST/RPC/Edge/SAP e tabelas novas. IAM/banco.
B10 • P2	Parcial	Limpeza aguardada e dono conferido; 5 testes browser.	Empresa nos snapshots e corridas de identidade. Frontend/QA.

As áreas são sugestões, não responsáveis nominais designados. Prioridades preservam a ordenação de trabalho; não representam compromisso de prazo. Rotação e restauração não devem esperar a conclusão de todas as correções de código.

A remoção de permissões implícitas exige revisar acessos legítimos antes de homologar. A solução não deve ser reabrir acesso amplo para contornar falhas de cadastro de grupos.

Backlog consolidado • B11–B20

O tratamento de N01–N04 amplia o progresso, sem encerrar o escopo global

Item	Estado	Avanço	Próxima evidência / área sugerida
B11 • P2	A fazer	IA/documentos permanece parcial.	Formatos, dados nos pixels, retenção e aprovação do provedor. IA/privacidade.
B12 • P1	A fazer global	Grants das novas RPC/tabela testados localmente.	RLS/EXECUTE completos por perfil e ambiente. Banco/segurança.
B13 • P2	Parcial	N01/N04 e dois schedulers tratados.	Inventário integral, contas técnicas e credenciais restritas. Backend/infra.
B14 • P1	Parcial	0063/0064 registradas e testadas com fixtures.	Replay integral e compatibilidade das trilhas. Banco/QA.
B15 • P1	A fazer	Audit antigo não representa o lockfile Bun efetivo.	Auditar grafo realmente implantado. Engenharia.
B16 • P1	Em reteste parcial	Reset próprio negado, contador e auditoria obrigatórios.	Auth real, concorrência e política de recuperação. IAM/QA.
B17 • P2	Parcial	Erros genéricos em handlers selecionados.	Revisão de todos os retornos/logs sensíveis. Backend.
B18 • P2	A fazer	Fronteiras de rede/arquivos não encerradas.	SSRF, storage, webhooks e browser. Segurança/backend.
B19 • P0/P1	Parcial	N02/N03: estado fiscal, reserva e reconciliação.	CNAB/hash/autoaprovação/replay e recuperação SAP real. Financeiro/QA/backend.
B20 • P2	Em andamento	Evidências locais, hashes e autoria N04.	Deploy, autor/revisor, alertas, retenção e recertificação. Segurança/QA.

Ordem recomendada para continuidade

- Validar 0063/0064 e permissões legítimas; retestar os vetores P0 em ambiente representativo.
- Homologar reprocessamento fiscal e o caso real de reaprovação SAP; exercitar falhas entre ERP e banco.
- Em paralelo, obter rotação/revogação, ensaio de restore e evidência de TLS/perímetro.
- Completar matriz de impersonação e grants; depois ampliar browser, IA, inventário e dependências.

B19 foi elevado para incluir imediatamente o vetor N02. Para P0/P1, a evidência de fechamento deve acompanhar cada correção, sem aguardar um relatório final agregado.

Controles de liberação e riscos residuais

Condições para converter implementação local em encerramento operacional

Etapa / controle	Evidência exigida
1. Preparar ambiente	Replay integral de migrações em ambiente descartável representativo. Aplicar 0063 e 0064 antes dos handlers dependentes.
2. Revisar acessos	Matriz usuário × empresa × ação; perfis positivos/negativos; credencial técnica nos dois schedulers. Não inferir privilégios pelo nome da role.
3. Reconciliar legado	Inventário de NFs com erro e Drafts existentes sem nova correlação. Vincular antes de permitir reenvio.
4. Exercitar falhas	Timeout depois do POST, falha de persistência, worker interrompido, concorrência e mudança de status. Demonstrar ausência de novo POST em resultado incerto.
5. Homologar negócios	Reaprovação SAP, anexos, UDFs, impostos, período contábil, linhas novas/removidas/gratuitas e documentos encerrados.
6. Medir operação	Latência/carga após retirada de caches; respostas 403/423/503; trilha e alertas úteis ao suporte.
7. Registrar aceite	Commit implantado, versões de ERP/add-ons, ambiente, data, autor/revisor, efeitos observados e testes positivos/negativos.

Recuperação de reservas

Se o processo morrer em processing, comprovar que não está ativo e buscar o Draft pela correlação. Operador autorizado pode mover a reserva específica para uncertain para reconciliar **sem novo POST**. Se o resultado não for conhecido, manter bloqueada. Não apagar a reserva por idade, nem tratar timeout como ausência de documento no SAP.

Ponderações para decisão

- Falhar fechado reduz autorização indevida, mas torna indisponibilidade de dependências visível ao usuário. Medir e preparar suporte.
- Reservas duráveis favorecem integridade frente à disponibilidade; recuperação assistida precisa de dono e trilha.
- Testes com mocks não exercitam políticas reais, gateway, serviço de email, SAP ou add-ons; reteste implantado é indispensável.
- Não há aceite de risco formal ou autorização para considerar TLS, rotação ou restore dispensados.

Este relatório não autoriza mudanças em produção, não comprova ausência de todas as vulnerabilidades e não substitui homologação ou revisão independente.

Índice de evidências e reprodução

Links apontam para os arquivos do commit de referência

ID	Artefato do repositório	Uso
EV01	security-remediation-2026-09-28/regression-tests.txt	15 testes de segurança
EV02	security-remediation-2026-09-28/database-tests.json	14 verificações SQL
EV03	security-remediation-2026-09-28/validation.json	Manifesto/resultados rodada 1
EV04	security-remediation-2026-09-28/round2/browser-tests.json	5 cenários Chrome
EV05	security-additional-review-2026-09-28/reproduction-results.json	Reprodução histórica N01–N04
EV06	security-v4.2-evidence/handler-tests.txt	12 testes de handlers/fluxo
EV07	security-v4.2-evidence/patch-tests.txt	6 testes específicos PATCH
EV08	security-v4.2-evidence/database-tests.json	6 cenários PostgreSQL
EV09	security-v4.2-evidence/deno-comparison.json	Comparação Deno 25/25
EV10	security-v4.2-evidence/manifest.json	15 arquivos V4.2 e hashes

Comandos registrados

```
node --test scripts/security-review/regression.test.mjs
node scripts/security-review/database-regression.mjs
node scripts/security-review/browser-local-state.mjs
node --test scripts/security-review/v42.test.mjs
npx vitest run src/lib/sap-document-patch.test.ts
node scripts/security-review/v42-database.mjs
npm test
npm run build
```

Os scripts SQL têm destino fixo de loopback e fixtures sintéticas. O ensaio 0064 cria banco temporário exclusivo e o remove; não replica dados. O script de achados adicionais reproduz vulnerabilidades do baseline e não deve ser interpretado como suite de aceitação do código atual.

As fontes autorais para contextualizar os artefatos são [backlog V4.1](#), [registro da candidata](#) e os READMEs de cada rodada. Contagens de build/Vitest geral são registros consolidados; os logs completos dessas execuções não estão anexados a este PDF.

Integridade, referências e controle de emissão

Correspondência documental conferida em 28/09/2026

Commit atual: ff8676ddb80e1f48d6e5bd16fbf8305180fa356a. O manifesto V4.2 foi produzido antes do commit e conserva o HEAD-base histórico. Nesta emissão, os **15 arquivos** nele listados conferem por SHA-256 com o checkout atual; os **9 arquivos** do manifesto de logout também conferem.

Três arquivos de handlers do manifesto da revisão adicional diferem por terem sido corrigidos depois da reprodução. Isso é esperado: o manifesto antigo é prova do baseline, não do estado corrigido. Evidências históricas não foram regravadas para aparentar encerramento.

Artefato	SHA-256 do artefato de evidência
EV06 12 testes de handlers/fluxo	68ac7ebd2c9f9e0a5882fe68c4eea2dae6848cfbabac0d7b5e228bb9a6b2ddbc
EV07 6 testes específicos PATCH	5e61bbd08e4bc89113d2a3f04e019f0d74bda26d9d835c647dfa55f24507ffab
EV08 6 cenários PostgreSQL	0c34db299f3141393618e7db6582f5a6e200ed028ccf42ea8eded4cc9c04de3e
EV09 Comparação Deno 25/25	2987119e7b9ab4ea412d17d4baade62d4e3ff618ee292c33e7ce3fbc0d9a21b4
EV10 15 arquivos V4.2 e hashes	af744c278a11926c8c55e0332e6fffb4eaf149de1cabcb27c6585cd046332ba4

Identificação das fontes originais

O backlog registra o V4.1 extraído do ZIP fornecido e o confronto com PDFs/DOCX V4.0. Os relatórios citaram um commit diferente do checkout-base; não se determinou se cada divergência era regressão ou erro de avaliação. Referências inexistentes e algoritmos de cifra divergentes foram explicitamente ponderados.

V4.1 original — SHA-256

191cd3725279f6bb2e484fc240268df8ec46957c5a46f63d6712a989203db1d8

Referência técnica externa

[SAP Business One Service Layer — API Reference](#): referência consultada na implementação do contrato de PATCH. Não substitui evidência da versão SAP e dos add-ons do cliente.

Registro de aprovação

Engenharia: código e testes locais registrados. **QA/SAP:** homologação real pendente. **Segurança:** revisão independente não registrada. **Dono do risco:** nenhum aceite ou encerramento operacional declarado.

O arquivo de integridade ao lado do PDF registra hash desta emissão e das fontes utilizadas. Não inclui senhas, tokens, documentos fiscais reais ou detalhes de conexão de produção.